

Cybersecurity Incident Registry

Documentazione amministrativa completa

Applicazione	Cybersecurity Incident Registry
Versione	0.5.0-1
Build	20260522
Autore	Alessandro De Salvo <Alessandro.DeSalvo@roma1.infn.it>

Questa guida descrive l'amministrazione completa dell'applicazione: ruoli, utenti, LDAP, OAuth2/SSO, liste, categorie, notifiche, moduli PDF, documentazione, export, import, backup e controlli periodici.

Indice

1. Responsibilities, prerequisites and work method
2. Admin menu organisation
3. Users, roles, MFA, LDAP and SSO
4. Multiple OAuth2/SSO profiles
5. Configurable lists, labels and recommendations
6. Organisation data and logo
7. SMTP, templates and notification scheduler
8. Incident reminders and restart recovery
9. PDF templates and form mapping
10. Audit, retention, purge and CSV export
11. Full export, import, backup and restore
12. Optional HTTPS/SSL
13. Language, documentation and Help menu
14. Operational checklists and troubleshooting

cybersecurity-incident-registry

•

Administrator documentation

Complete guide to application configuration, security and maintenance.

Go to index Download administrator PDF

Clear, verifiable and repeatable administration

This guide reorganises administration by area: identity, security, taxonomies, notifications, forms, audit, export/import, SSL and maintenance. It keeps the previous operational style while separating procedures, examples and checklists more clearly.

Application version: 0.5.0-1 · Version 0.5.0-1 of the administrator guide.

Application Cybersecurity Incident Registry

Application version 0.5.0-1

Build 20260522

Note Version 0.5.0-1 of the administrator documentation.

Scheduled notification status: the Notifications page now also shows scheduled/sent/error states and recent outcomes automatically updated by the scheduler.

Service status: Admin → Status shows scheduler threads, heartbeat, deadline-task cycles, incident-specific reminder cycles, backup scheduler, errors and operational counters.

When the template allows manual CC editing, the preview pre-fills it with the template default when present; if the operator clears it before confirmation, the email is sent without CC.

Manual notification templates also expose %RISK_RIGHTS_FREEDOM% , %RESP% , %RESP_EMAIL% , %DIRECTOR% and %DIRECTOR_ROLE% . The legacy %PERSONAL_DATA% placeholder is automatically migrated in existing templates.

Under Admin → Other configurations , the Automatic consequence logic section lets administrators enable/disable, add, remove and customize rule texts and conditions for the form field consequences . Consequences entered on incident actions are always appended to the result. The same page includes an Orphan document cleanup button that removes only application-generated files in uploads that are no longer linked to any incident, without deleting manually uploaded attachments.

AI Chatbot: Admin → Plugins can enable the optional AI Chatbot plugin, choose one engine among ChatGPT, Claude, Gemini, Ollama and Perplexity, configure endpoint/model/API key and upload procedural documents used as knowledge base. The global backend reset button restores active engine, endpoints, models and API keys to the default values, while the per-engine buttons reset only the selected backend endpoint, model and API key. These resets do not change plugin enablement or the database-context option.

AI Chatbot and database: Admin → Plugins can optionally enable a sanitized current-database snapshot. The option is disabled by default and filters personal data, credentials, tokens, email addresses, binary attachments and potentially identifying free text before sending context to the AI engine.

AI Chatbot widget: when the plugin is enabled, the base layout shows the launcher on every page. On desktop it is a floating icon preferably in the bottom-right area above the decorative logo; JavaScript recalculates its position to avoid collisions with the logo, viewport edges and main fixed elements. On mobile the open button is at the top next to the menu and moves to its own row on narrow screens.

AI Chatbot API keys: in Admin → Plugins existing API keys are shown only as masked values; the real value cannot be displayed and can only be overwritten by entering a new key or cleared by resetting the relevant backend configuration.

Plugin Alfresco

La voce Admin → Plugin Alfresco consente di abilitare il plugin opzionale, disabilitato per default, e configurare endpoint API, credenziali, site, cartella di destinazione, timeout e verifica TLS. Quando abilitato, la sezione Documenti degli incidenti consente upload e download tramite API Alfresco.

Search administrator documentation Type a word to filter chapters.

1. Responsibilities, prerequisites and work method

Flusso amministrativo consigliato

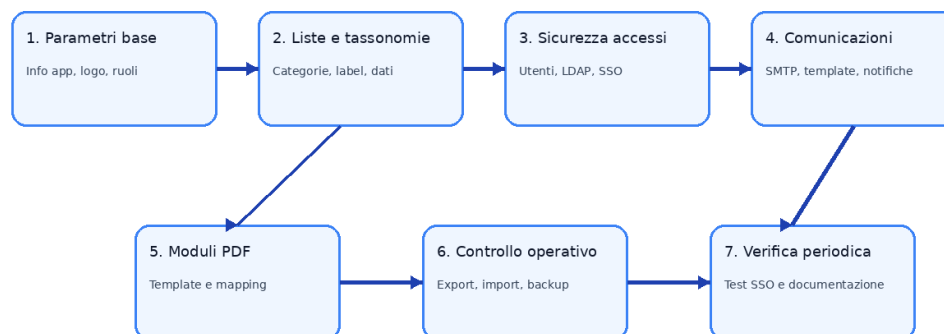


Figura 1 - Flusso amministrativo consigliato

Administration functions are reserved for the admin user and users with the admin role. Changes in this area affect security, data, reports, notifications and operating procedures.

Before changing critical settings, verify that a recent backup and a restore procedure are available. Changes must be traceable: the system records operations in the audit table and reduces flooding by collapsing consecutive identical records.

Recommended prerequisites

- Personal, non-shared administrator account.
- SMTP, LDAP, SSO or SSL parameters validated before activation.
- Persistent directory for documents, certificates and application files.
- PostgreSQL backup and full application export procedure. Configurable backups from the Admin menu

The Admin → Backup entry allows administrators to configure scheduled and on-demand backups. Multi-select categories are incidents as CSV, database, templates, logos and uploads; all are selected by default and, when all remain enabled, the result is an application full backup. Scheduling uses a five-field cron-like syntax and is disabled by default. Available destinations are local POSIX filesystem, S3/compatible storage and downloadable file for on-demand backups only. The administrator can enable e-mail notifications to the admin user for success or failure and can upload an archive for restore/verification operations.

Actions associated with the automatic operation Close task when no procedural warnings are active close the incident and set the current application-timezone date and time only when no procedural warning remains after the action has been recorded.

2. Admin menu organisation

The Admin menu is organised into collapsible groups to avoid a very long list. On page load no subgroup is open by default, making navigation predictable.

Available entries depend on the user role. Main areas include identity, operational settings, notifications, forms, audit, SSL and organisation data.

2a. Production hardening

For real operation set CIR_PRODUCTION=1, use PostgreSQL, generate a random SECRET_KEY of at least 32 characters and define a strong temporary initial admin password. docker-compose.yml contains no secrets: copy .env.example to .env and change every value before startup.

The application applies automatic CSRF protection to mutating forms, security headers, HttpOnly/SameSite cookies and Secure cookies in production. The internal scheduler uses a PostgreSQL lock to avoid duplicate executions with multiple

workers or Kubernetes replicas.

2b. Environment variables and container operations

Container operations are also documented in docs/CONTAINER_ENVIRONMENT_en.md . Before production startup, copy .env.example to .env , replace every secret and make sure all directories under /data are mounted on persistent volumes or PVCs.

Area Main variables Operational guidance

Database and secrets DATABASE_URL , SECRET_KEY , ADMIN_INITIAL_PASSWORD , POSTGRES_PASSWORD Use PostgreSQL in production, a random SECRET_KEY of at least 32 characters and a strong temporary admin password. POSTGRES_DB and POSTGRES_USER must match DATABASE_URL .

Production and HTTP security CIR_PRODUCTION , SESSION_COOKIE_SECURE , CIR_FORCE_HSTS , MAX_CONTENT_LENGTH Set CIR_PRODUCTION=1 and secure cookies when the application is served through HTTPS. CIR_FORCE_HSTS=1 is useful behind a TLS reverse proxy.

Persistent storage UPLOAD_DIR , LOGO_DIR , FORM_TEMPLATE_DIR , SSO_LOGO_DIR , SSL_DIR They contain attachments, the application logo, PDF templates, SSO logos and certificates. Back them up together with PostgreSQL.

HTTP/HTTPS and Unicorn PORT , WEB_CONCURRENCY , GUNICORN_THREADS , GUNICORN_TIMEOUT , SSL_ENABLED , SSL_PORT , SSL_CERT_FILE , SSL_KEY_FILE The entrypoint always starts HTTP and starts HTTPS when enabled and when certificate and key are readable. Size workers and threads according to available resources.

Scheduler CIR_ENABLE_DEADLINE_SCHEDULER , CIR_DEADLINE_SCHEDULER_POLL_SECONDS The scheduler is enabled by default and uses PostgreSQL locks in multi-replica deployments. Disable it only if an external component runs scheduler tasks.

Application metadata APP_NAME , APP_VERSION , APP_BUILD , APP_AUTHOR , APP_AUTHOR_EMAIL Values shown in Info → Application and useful for audit, release and support.

Typical operations: docker compose up -d to start, docker compose logs -f web for logs, docker compose down to stop without deleting data. Do not use docker compose down -v in production because it removes volumes.

In Kubernetes, application secrets are read from cir-secrets ; persistent areas must be mounted through PVCs. Before an upgrade, back up the database and volumes, then rebuild or redeploy the image.

3. Users, roles, MFA, LDAP and SSO

Admin → Users manages local, LDAP and SSO accounts, roles, e-mail addresses, MFA and account removal. Keep at least one emergency local admin account even when LDAP or SSO is enabled.

TOTP MFA can improve login security. LDAP authenticates against external directories; SSO/OAuth2 integrates OpenID Connect providers.

In the users table, the Login type column distinguishes SSO accounts by provider: it shows the configured provider name, the profile id and the technical backend in the sso:<profile id> format. This lets administrators recognise the same username correctly when it exists as a local, LDAP or multiple-provider SSO identity.

Removing a user deletes the account and its MFA tokens, preventing future access. Incidents, reminders and audit records are preserved: the system only detaches the technical reference to the removed account, keeping historical traceability. For safety, the currently signed-in administrator and the last remaining administrator cannot be removed.

Role Recommended use

admin Application configuration and maintenance.

writer Operators creating and updating incidents.

reader Reviewers or read-only users.

operator Restricted operational access.

4. Multiple OAuth2/SSO profiles

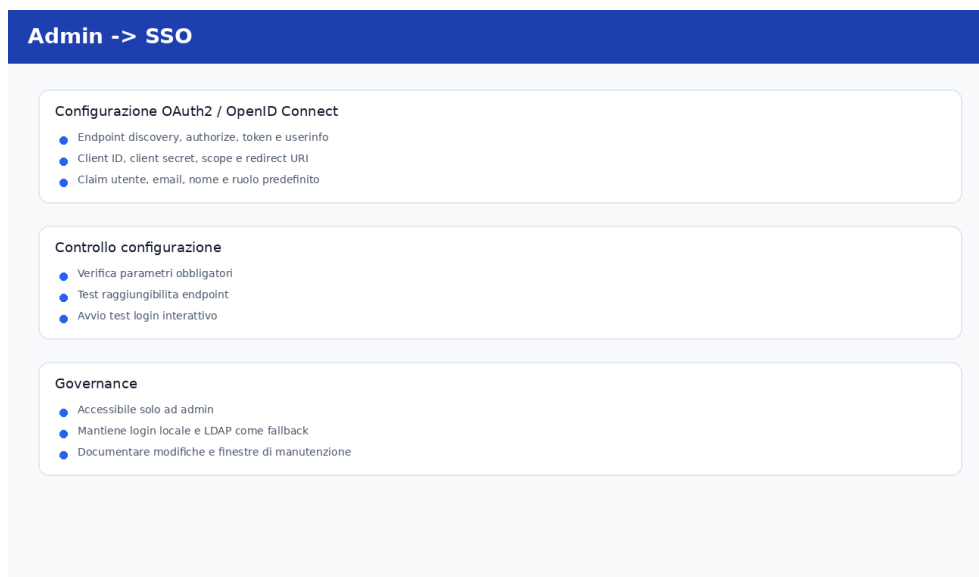


Figura 2 - Configurazione SSO e controllo connessione

The application supports multiple active OAuth2/OpenID Connect profiles at the same time. The login page displays the active providers.

The callback/redirect URI shown in the form always uses the https scheme. The page provides buttons to add a Google example profile or a generic profile. Each profile can also have an optional logo; if configured, the logo is shown on the login button. The Google example uses the bundled Google logo by default, which can be replaced from the profile form.

Shared SSO/OAuth2 logos

SSO logos are managed in a shared storage area from Admin → SSO/OAuth2 . The upload button adds new logos to the persistent storage configured through the SSO_LOGO_DIR environment variable, while each profile configuration lets administrators select one of the available logos.

Google, Facebook and Apple are provided as default logos and are copied to persistent storage on startup when missing. Administrator-uploaded logos must not be stored in the container static area because it may be ephemeral: in production, the path configured by SSO_LOGO_DIR , default /data/sso_logos , must be mounted on a persistent volume or PVC.

The SSO logo storage list shows both the file name and a graphical preview for each logo. Previews are served through the application persistent-logo route, so they must work for both default logos and logos uploaded from the UI. If a preview is missing, check that the file exists in the directory configured by SSO_LOGO_DIR , that the extension is supported and that the persistent volume is mounted correctly.

Removing a logo from shared storage automatically clears the association from SSO profiles that used it, without deleting the profiles. Full export/import includes SSO logos, which is useful for migrations and application-level restores; persistent storage backups are still required.

Google example

- Add the Google profile.
- Register the displayed HTTPS redirect URI with Google.
- Fill Client ID and Client secret.
- Review scopes, endpoints, claims and the optional logo.
- Replace the default Google logo only if required by local branding rules.
- Enable the profile and perform a real login test.

5. Configurable lists, labels and recommendations

Configurable lists govern categories, affected data, action labels and other values used by incidents. In action labels, the card view separates name, description, maximum time, default export flag and automatic operations. Maximum time (hours) states the unit of measure and Exportable by default determines the initial value for new actions.

Admin → Recommendations manages recommendations and the maximum number that can be selected per incident. The default is 3; the limit is enforced in the UI and server-side and is included in full export/import through application settings.

6. Organisation data and logo

Security owner, structure and responsible-person entries feed dynamic fields in forms and reports. The custom logo can be uploaded from the interface and is used where expected; the application logo remains separate and is shown in incident PDF reports.

If no custom logo is configured, the report omits it and still shows the application logo.

7. SMTP, templates and notification scheduler

Notifications require valid SMTP settings and coherent templates. For manual/non-scheduled notifications, the direct incident link is inserted only when the template contains %INCIDENT_URL% .

Incident documents can be tagged with one or more notification types directly in the document list through drag & drop. These tags drive attachment preselection during sending, without preventing the operator from changing the final selection. Generated PDF form documents automatically inherit only the notification-type tags configured directly on the form template used for generation.

Each manual template can optionally be linked to a PDF form template. When sending from an incident, documents generated from that form template are preselected automatically; the operator can still add other documents or deselect the proposed ones. If the expected document is not present, the system shows a non-blocking warning.

Admin → External recipients manages the shared address book used by manual notification recipient/CC fields when the recipient is free, that is, not already taken from application settings: administrators can add, edit, delete and search contacts by name, e-mail or notes. Non-administrator users with the writer role can manage and search the same address book from Settings → External recipients , without access to the Admin menu. In the send preview the operator can select a contact from the address book, seeing both name and e-mail, and use it as recipient or CC. For free recipients the application always asks for an explicit confirmation before delivery, summarising recipient and CC; new emails entered during sending are added to the address book using the incident Reference field as the recipient name, without blocking delivery to ask for extra data.

Manual template placeholders include %MEASURES_ADOPTED% ("list of countermeasures adopted so far in the incident"), %RECOMMENDATIONS% ("list of recommendations to provide to affected data subjects, same value as the form field recommendations "), %INCIDENT_URL% , %SITE% ("name of the structure where the incident occurred") and %STATISTICS% , which attaches the PDF statistics report to the notification.

Deadline task notifications use cron-like scheduling with specific times or intervals. Slots are calculated from midnight in the application timezone, not from application startup. The scheduler writes audit records only when notifications are sent or at the scheduled slot when notifications would have been sent even if none are found.

To avoid duplicates, the scheduler stores a persistent slot claim before sending: this prevents resending inside the same interval even if multiple workers, replicas or opportunistic checks try to send at the same time. Each cycle also removes stale states referring to deleted incidents.

Settings → Notifications includes a summary of the next scheduled notifications in the following 24 hours, sorted by time and showing notification type, incident and expected recipients. The list includes one-off incident reminders and future slots for automatic deadline-task notifications.

8. Incident reminders and restart recovery

One-off incident reminders are defined by operators with date, time, message and optional CC. The scheduler sends them to personnel associated with the incident.

After restart, all overdue one-off reminders whose sent_at value is still empty are recovered. The technical claim only prevents concurrent delivery of the same record and does not apply the period block. For periodic notifications, recovery sends only the latest notification expected for each type.

9a. Incident field contextual help

The incident detail form includes online help icons for the main fields. The help texts explain mandatory values, recipients, breach period, awareness date/time, personal-data implications, muted deadline notifications and the data-subject/data-volume fields. Administrators should keep operational procedures aligned with these definitions.

9. PDF templates and form mapping

PDF templates are analysed to extract AcroForm fields. Administrators map each form field to an incident database field or dynamic value. The same configuration lets administrators associate one or more notification-type tags with the template through drag and drop; tags are displayed by notification type name and are applied by default to documents generated from that template. Filling uses configured font family and size.

Before generation, the application checks missing data and asks the user to complete it in the relevant section.

AI Chatbot plugin AlBot/Alex

Admin → Plugins enables the optional AI Chatbot plugin, lets administrators choose one engine among ChatGPT, Claude, Gemini, Ollama and Perplexity, configure endpoint/model/API key values and upload procedural documents used as knowledge base. Existing API keys are shown only as masked values: the real value cannot be displayed and can only be overwritten or cleared by resetting backend configurations. The global backend reset button restores the active engine, endpoints, models and API keys to default values, while each engine also has a dedicated reset for its endpoint, model and API key only. These resets do not change plugin enablement or the database-context option.

10. Audit, retention, purge and CSV export

The audit table records user, scheduler and automated task operations. Details are concise and readable, avoiding large payloads that are not useful during review.

Time retention is configured in months, days, hours and minutes, defaulting to 6 months. Automatic purge also runs when the maximum number of records is exceeded; the default maximum is 10000 and can be configured in Admin → Audit .

The same page provides manual purge by keeping only a specified number of records or deleting records older than a selected date. CSV export is available for the current filtered audit view. Audit browsing is paginated, default 20 and maximum 100 records per page. Displayed dates, filters, purge dates and CSV export values use the configured application timezone.

11. Full export, import, backup and restore



Figura 3 - Configurazione template PDF e mapping

Full export/import includes incidents, documents, forms, settings, audit, notification states, reminders, SSO profiles, SSO logos and SSL certificates. It is useful for migration and application-level backups, but does not replace PostgreSQL and persistent-storage backups.

Recommended backup

- Back up the database.
- Back up persistent file storage.
- Download full export periodically.
- Test restore in a separate environment.

12. Optional HTTPS/SSL

The container exposes port 8443 for optional HTTPS/SSL. HTTP on port 8000 always remains available and must not be blocked by missing certificates.

HTTPS can be enabled through Docker Compose or Kubernetes environment variables and from Admin → HTTPS/SSL . Host certificates can be provided by deployment configuration or uploaded through the web interface. If HTTPS is requested but valid certificates are not available, the application still starts HTTP access.

13. Language, documentation and Help menu

The application maintains the interface and documentation in Italian and English. Functional instructions are provided in Italian and translated into the English version as well.

The Help menu contains User documentation , Administrator documentation and Release notes . Direct PDF download entries are not in the menu; each page has its own PDF download button.

README.md is maintained in Italian and README_en.md in English.

14. Operational checklists and troubleshooting

Monthly checklist

- Verify backup and restore tests.
- Review audit, retention and purge.
- Check automatic notifications and reminders.
- Check SSL certificate validity and SSO settings.

- Review active users and assigned roles. Common issues
- SSO does not work: verify HTTPS redirect URI, client secret, endpoints and claims.
- E-mails do not arrive: check SMTP, templates, recipients and scheduler audit.
- PDF form is incomplete: check mapping and required incident fields.
- Audit is too large: verify retention, maximum records and manual purge.

Incident operational workflows

From Admin → Incident operational workflows administrators define the operations expected for incidents. Each step uses an action label from the database, so available actions remain extensible from Admin → Configurable lists .

Each step belongs either to the default workflow or to a specific category and includes the expected action, an additional operational description, an order and whether the step is required for procedural warnings. The same action may appear more than once with different descriptions; every step can be edited, added or deleted, including default-workflow steps.

The initial default workflow contains: Initial information, Analysis, CSIRT notification, DPO notification, Privacy Authority communication, user communication and Closure. On the incident detail page the caption uses the action-label description when available, otherwise the label name; the workflow-step description is shown as an additional note. If the action label has a maximum completion time, the incident page shows limit, due time and remaining time only for steps that have not yet been completed; a missing step whose remaining time is less than or equal to zero is highlighted as critical.

On the incident detail page category workflows are merged, duplicates are removed and, if none exists, the default workflow is applied. Step cards are clickable: selecting one jumps to the Actions section and preselects the associated label, making it easier to record the missing action. The lower step caption uses the configurable description of the step type, such as Confirmation or Execution, instead of a fixed text. Multiline descriptions support safe Markdown, controlled colours and controlled font sizes, for example **urgent** , lists, Markdown links, button links such as {button:Open section|#incident-main} , {color:red}text{/color} and {size:large}text{/size} ; absolute and relative URLs are clickable on the incident page and do not intercept the general card click. Procedural warnings are placed immediately below the workflow, use the same Markdown renderer and also show the associated task name.

Incident templates

From Admin → Incident templates , administrators can define predefined profiles used to initialise a new incident. Each template can contain name, reference, recipient, description, severity, status, personal-data flag, categories, affected data types, involved people and recommendations. Actions and documents are not included in templates. The category order selected by drag and drop is preserved when the template is saved and edited again.

A template can also be created from an existing incident: the system copies only bootstrap data and excludes actions and documents. When creating from a template, the incident start date and time are always set to the current moment. Templates can be applied only while creating a new incident: existing incidents can still be edited manually, but they no longer expose template application controls.

Admin → Users includes search by username, name, e-mail, backend and role. User removal records the audit event after realigning the PostgreSQL sequence to avoid duplicate-key errors on imported databases.

Destructive full import

Full import fully replaces the application database: after archive validation, the schema is dropped and recreated before data is restored. This removes previous data, leftover tables and misaligned PostgreSQL sequences. Always take a backup of the database and persistent volumes before using it in production.

PostgreSQL user sequence repair

When new users are created, including local accounts, LDAP accounts created on first login and automatically created SSO accounts, the application realigns the PostgreSQL sequence of the user table. If manual creation from Admin → Users detects a user_pkey collision, the system rolls back, persistently realigns the sequence and retries the insert. This prevents errors after full import, restore or data loads with explicit IDs.

PostgreSQL audit sequence repair

User operations always write an audit entry. After PostgreSQL import or restore, the application automatically realigns the audit_log sequence before critical inserts and retries the audit operation if an audit_log_pkey collision is detected. This prevents errors while adding, updating or deleting users.

Database sequences and full imports

Since version 0.5.0-1 the system automatically realigns all PostgreSQL sequences for application tables with integer primary keys after Full import and restore. This prevents duplicate key value violates unique constraint errors during later creation of users, incidents, actions, documents, workflows, templates, recipients, backups and audit records.

Full import remains destructive: the schema is recreated completely before loading data and all sequences are realigned afterwards.

Mandatory incident reference

The Reference field is mandatory for every incident and is validated both in the UI and on the server. During migrations and Full import, older records without a reference are normalized with a technical value based on the id, keeping the database consistent with the application rule.

External recipients in incident data

In incident General Data and in Admin → Incident templates , the external recipient address book can fill Reference, Recipient or Recipient e-mail. LDAP incident lookup can return multiple users: the page lists all results and, for each row, all attributes configured as incident search attributes, so the operator explicitly selects the row to use. When Recipient e-mail is set, it must be a valid e-mail address and Reference or Recipient must also be present. New e-mail addresses not yet in the address book are added automatically using Recipient or Reference as name. Manual notifications cannot be sent or confirmed without at least one effective recipient. If the template allows manual recipient or CC editing, values typed in the preview are read directly at submit time for both delivery and confirmation without sending; empty or invalid recipient/CC values are rejected with an explicit error. Editable CC is prefilled from the template default when present, but a manually cleared CC is honoured at confirmation time.